

国创赛 2026

高教主赛道

创意组

Agent eBPF Filter

面向 AI Agent 的 内核级运行时安全与可观测平台

让 Agent 的“承诺”和操作系统里的“事实”对齐起来

eBPF

内核事实

LSM

同步阻断

Graph

执行归因

负责人 / 学院 / 联系方式

【待填】

推荐学院：待填

负责人：待填

手机号：待填

QQ：待填

项目答辩 / 路演版 · 2026-05-25

路演结构：从真实痛点到代码证据，再到商业落地

遵循高教主赛道创意组：个人成长、项目创新、产业价值、团队协作。

01

调研痛点

OWASP / Five Eyes / GitGuardian 都指向：Agent 高权限执行链需要 runtime guardrail。

02

用户画像

开发者怕密钥外泄，安全团队怕不可审计，平台团队怕推广 Agent 后无法追责。

03

技术闭环

eBPF 事实层 + hooks 语义层 + BPF LSM/cgroup 阻断 + 执行图谱。

04

代码证据

lsm_enforcer、cgroup_sandbox、event_context、semantic_alerts、execution_graph 已有实现。

05

商业落地

高校 / 实验室试点切入，扩展 AI coding 团队、企业私有化与教育服务。

问题：Agent 安全已从“回答错”变成“三个不可见”

编码 Agent 会启动终端、修改文件、安装依赖、访问网络，安全边界必须落到运行时。

意图不可见

- EDR 看得到进程，却不知道哪个 run/task/tool_call 触发
- Prompt 网关看得到文本，看不到 OS 行为

链路不可见

- 危险动作常发生在 shell/python/node/git/npm/curl 子进程
- MCP 配置、skills、依赖脚本扩大本机攻击面

阻断不可见

- 事后日志难证明动作是否已被内核拒绝
- 安全团队需要可回放、可提交的证据链

结论：用户真正要的不是“再加一个大屏”，而是把 Agent 语义与操作系统事实合成可验证证据链。

典型风险链：Prompt 注入 → 工具误用 → 子进程漂移 → 数据外泄

项目从执行链而不是单条日志看待 Agent 风险。



观测对象

- 进程、文件、网络、策略、工具调用

判断依据

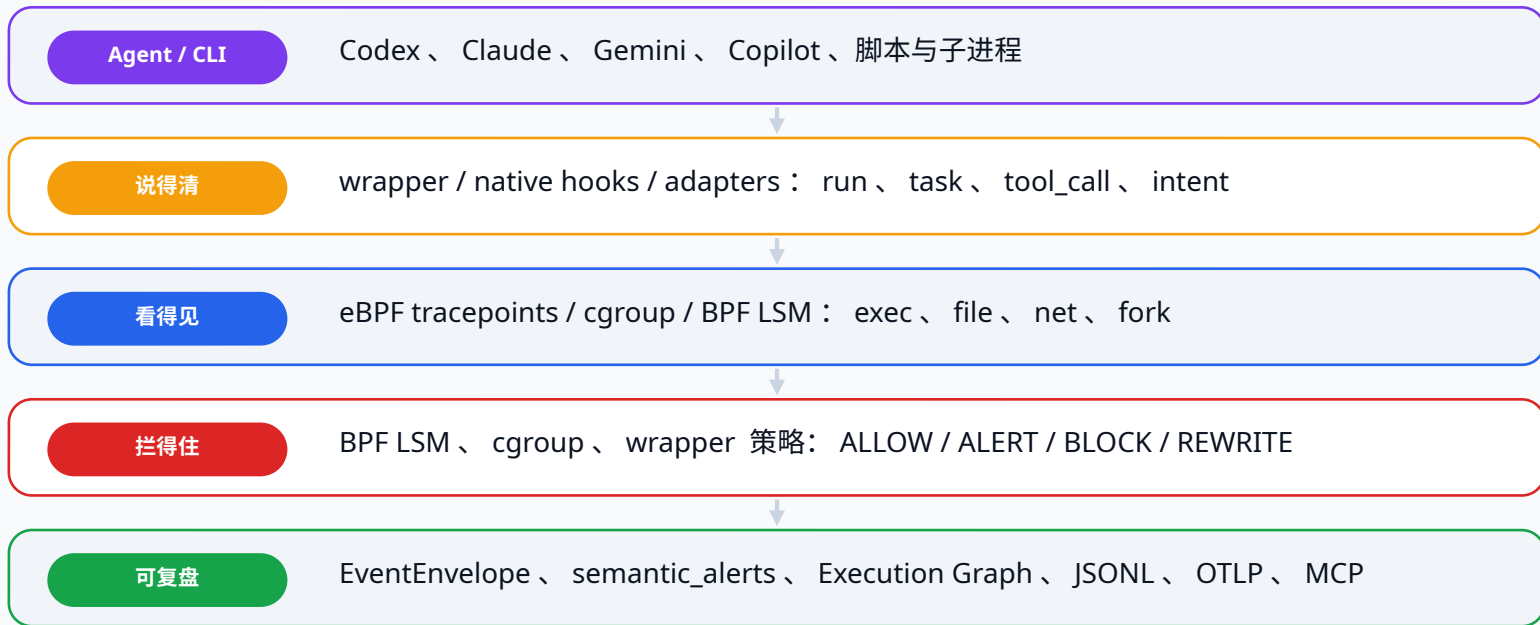
- 意图是否与事实行为一致

处置动作

- ALLOW / ALERT / BLOCK / REWRITE

解决方案：看得见、说得清、拦得住

以 eBPF 为事实底座，用 hooks/wrapper 补齐 Agent 语义，再进入图谱和策略闭环。



当前原型：已不是概念图，而是可运行工程

仓库已包含 Go 后端、eBPF 程序、Vue 前端、wrapper、适配器与部署脚本。

Go

特权后端 / API / 策略

eBPF

tracepoints/LSM/
cgroup

Vue

Dashboard/Graph/UI

Wrapper

命令控制 / UDS

ML

风险评分 / 训练集

后台能力

- event_envelope.go : 统一事件模型
- semantic_alerts.go : 语义风险告警
- execution_graph.go : 证据图谱

内核能力

- lsm_enforcer.c : exec/file/inode 阻断
- cgroup_sandbox.c : connect/sendmsg 阻断
- agent_tracker.c : 进程事实采集

产品能力

- Vue Dashboard / Execution Graph / Config
- 低代码 recipe 与 transpiler
- systemd / rc.local / K8s 部署文档

答辩要点：每个卖点都能指到代码文件、演示页面和验证脚本。

创新一： BPF LSM + cgroup 形成确定性内核阻断

不是只做事后日志，而是在 `exec/open/read/write/mmap/rename/connect` 等路径前置决策。

BPF LSM

- `bprm_check_security`：执行前检查
- `file_open / file_permission`：打开与读写
- `inode_*`：创建、删除、重命名、链接
 - 命中策略返回 `-EACCES`

cgroup 网络

- `connect4/connect6`
- `sendmsg4/sendmsg6`
- 按 `cgroup`、`IP`、`IPv6`、端口阻断
- 覆盖 `TCP/UDP` 外联场景

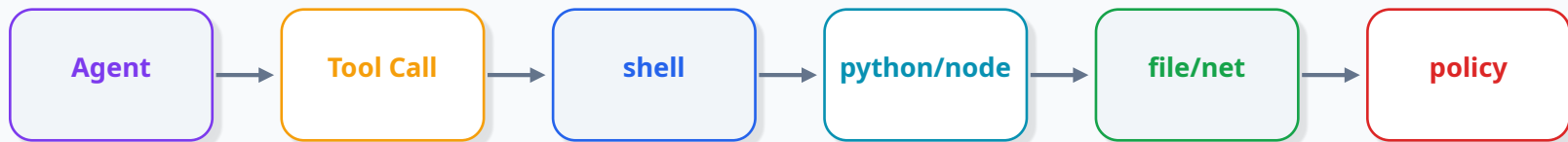
策略原则

- 确定性 `map lookup`
- `ML/LLM` 只建议不直接内核阻断
- 策略通过认证 `API` 修改
- 阻断证据进入执行图谱

评委可感知亮点：真实 OS 级拒绝，而不是 UI 上标红。

创新二：进程树追踪让 Agent 子进程不再“失踪”

真实 Agent 行为经常发生在 /bin/sh、python、node、git、npm、curl 等子进程。



继承字段

- agent_run_id / task_id / tool_call_id / trace_id

事实字段

- PID/TGID/PPID、comm、cwd、cgroup_id

复盘结果

- 一条链路回放所有子进程与对象

创新三：语义 - 事实一致性检测

把工具声明的意图与 eBPF 事实对比，识别“说是读文件，实际在外联 / 读密钥”。

语义输入

- tool_name / task / prompt 摘要
- wrapper 决策请求
- native hook 元数据

事实输入

- exec/open/connect/send
- 进程树、路径、网络端点
- BPF LSM/cgroup 决策

输出告警

- SECRET_ACCESS
- UNEXPECTED_NETWORK_EGRESS
- WORKSPACE_ESCAPE
- TOKEN_EXFIL_RISK

示例：任务声明为只读代码审查，但子进程访问 `~/ssh` 或向未知公网地址发送数据 → 触发高风险告警 / 阻断。

演示场景：三分钟证明“看得见、说得清、拦得住”

建议现场按 3 个最硬核场景演示，避免只展示大屏。

敏感路径

- Agent 尝试读取 .env / ssh key → SECRET_ACCESS + 任务归因

异常外联

- curl / python 子进程连接未知 IP:port → UNEXPECTED_NETWORK_EGRESS

内核阻断

- BPF LSM 返回 EACCES，cgroup 拒绝 connect/sendmsg

图谱回放

- Agent Run → Tool Call → Process → File/Network → Policy

答辩话术：我们不是只做可视化，而是在内核执行路径上获取证据并形成策略闭环。

与评审规则对齐：四个维度逐项回应

高教主赛道创意组重点：个人成长 30、项目创新 30、产业价值 25、团队协作 15。

个人成长 30

课程知识到 eBPF 原型；调研 Agent 安全真实问题；专创融合。

项目创新 30

BPF LSM、内核态阻断、进程树、语义 - 事实一致性。

产业价值 25

AI coding 团队、高校实验室、企业安全审计强需求。

团队协作 15

内核、后端、前端、算法、商业分工清晰。

目标市场： AI Agent 落地越快，运行时安全越刚需

从教育科研切入，扩展到 AI coding 团队和企业私有化部署。

高校实验室

- eBPF/AI 安全教学
- 课程实验与竞赛
- 软著 / 论文 / 项目成果

AI coding 团队

- 本地 / 云端 Agent 审计
- 敏感文件与外联治理
- 团队策略模板

企业安全

- 私有化部署
- 审计报表与 SIEM
- 合规留存

培训 / 靶场

- CTF/ 攻防演练
- Agent 安全训练
- 案例数据集

先低门槛开源获客，再用专业版 / 私有化 / 培训完成转化。

商业模式：开源核心 + 专业版 + 私有化 + 教育服务

保留技术影响力，同时形成可收费的团队、企业与教学版本。

Community**免费 / 开源**

单机观测、基础告警、教学实验

Team Pro**3.98 万 / 年起**

团队策略、报表、训练样本、多用户

Enterprise**19.8 万 / 年起**

私有化、多节点、SSO、审计留存、集成

Education Kit**3 万 / 套起**

课程实验、靶场、竞赛训练营

Consulting**5-20 万 / 项目**

PoC、红队 replay、策略调优

三年财务测算：从试点到专业版规模化

测算逻辑：高校 / 实验室试点 → 团队专业版 → 企业私有化与咨询。

第 1 年

80 万

5 个高校试点 + 3 个企业 PoC + 2 套教育包

第 2 年

420 万

20 个 Team Pro + 8 个 Enterprise + 8 个服务项目

第 3 年

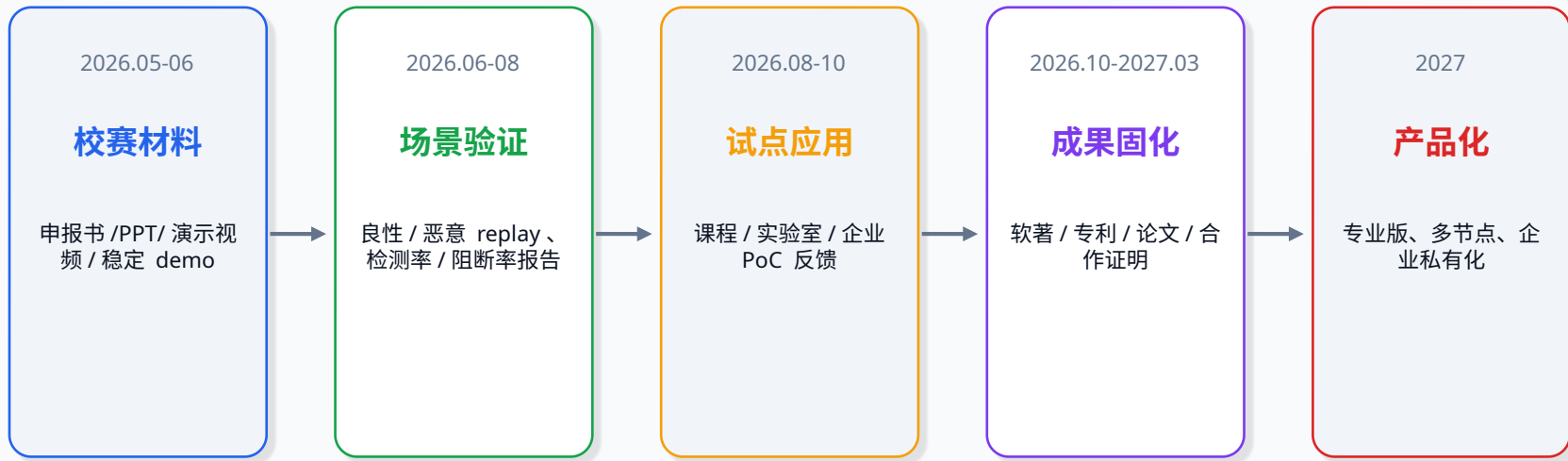
1600 万

60 个 Team Pro + 25 个 Enterprise + 20 个项目

提交前必须用真实调研、试点意向或合同报价替换测算，避免被评委质疑数据来源。

实施路线：材料提交后继续把原型做成可验证产品

围绕竞赛、试点、知识产权和商业化四条线推进。



团队分工：硬技术、产品、算法与商业材料协同

提交前将【待填】替换为真实姓名、学号、年级、学院与贡献证据。

负责人

- 【待填】总体架构 / 答辩 / 进度

eBPF

- 【待填】LSM / cgroup / tracepoints

后端

- 【待填】Go API / EventEnvelope / 策略

前端

- 【待填】Vue / 执行图谱 / 低代码

算法评测

- 【待填】semantic_alerts / ML / replay

商业调研

- 【待填】客户访谈 / 财务 / 路演

团队证明建议：commit 记录、模块负责人截图、导师指导记录、测试报告、软著 / 论文 / 专利分工。

风险与合规：高权限工具必须讲清楚边界

评委会关注安全工具自身是否安全，需主动说明默认关闭、鉴权和脱敏。

权限风险

- 后端需要加载 eBPF，保持 root/ 特权边界
- 写 API、shell、策略变更均有 token 与 runtime gate

隐私风险

- TLS 明文捕获默认关闭
- 事件流只保留摘要 / 长度 / 角色 / 厂商
- 演示数据必须脱敏

误报风险

- 先观察模式再阻断
- 回放 benchmark 调优
- ML/LLM 建议需人工确认

合规表述：本项目用于本地 / 授权环境的 Agent 安全观测与控制，不采集未授权数据。

总结：让 AI Agent 可观测、可解释、可回放、可控制

我们用 eBPF 把系统事实拿到，用 hooks/wrapper 把 Agent 语义接上，再用 BPF LSM / cgroup / 执行图谱完成安全闭环。

需要支持

- 导师 / 学院资源、试点用户、软著 / 专利指导

提交前

- 补真实团队信息、联系方式、调研数据与证明

目标

- 校赛晋级、省赛打磨、形成可转化产品

谢谢各位老师，请批评指正